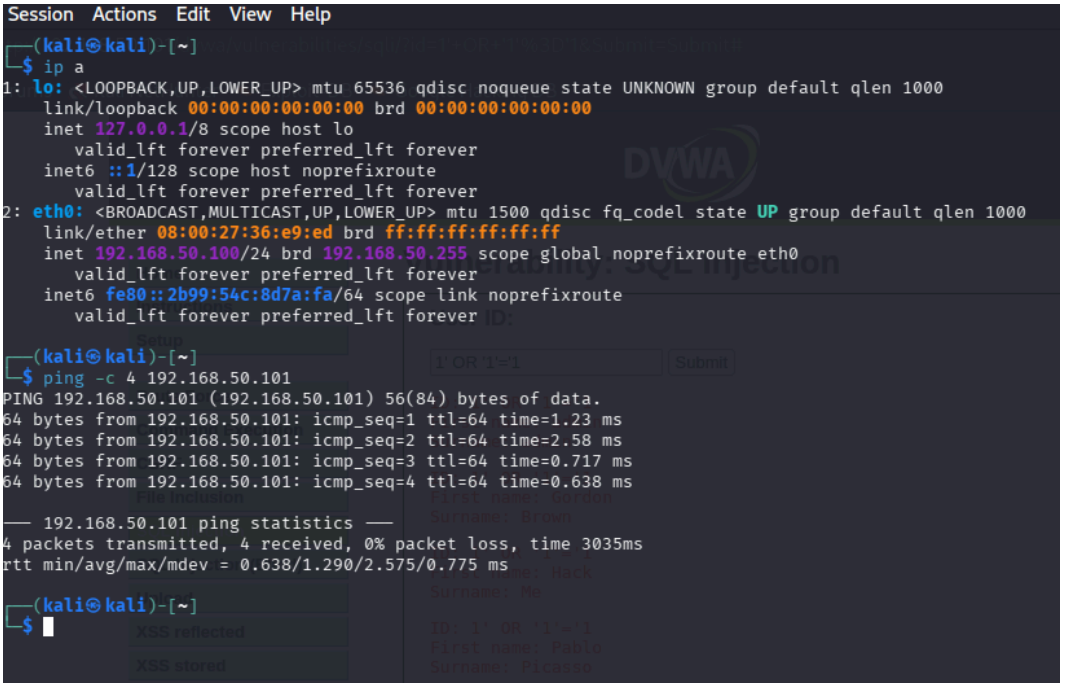
lab> XSS e SQL injection

Fase 1: Configurazione e Connettività

Prima di attaccare, le macchine devono "parlarsi".

1. ip) Per vedere l'ip di kali = 192.168.50.100
2. **Ping:** Su Kali(ip: , `ping 192.168.50.101` `= (ip di metaspotabile)`. per vedere se le macchine si vedono

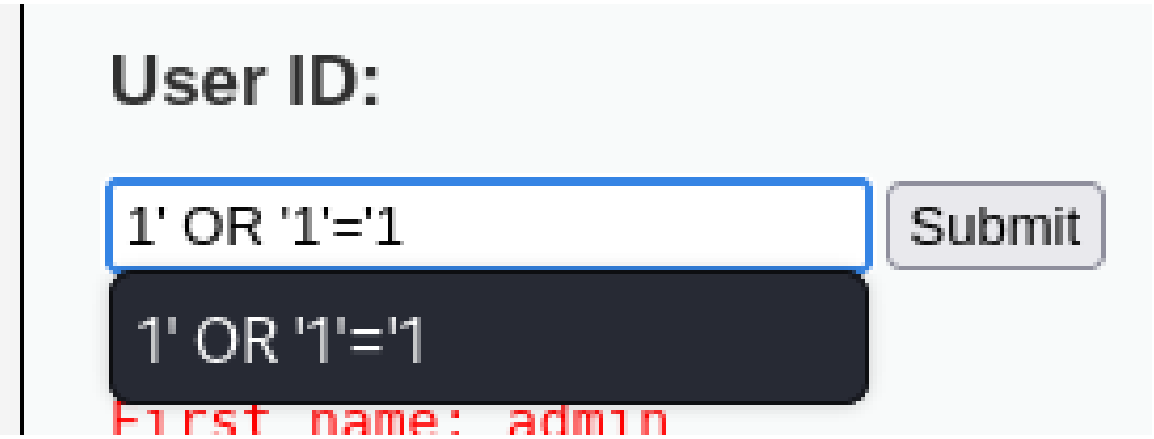


3. **Accesso:** Accedere su `http://192.168.1.50/dvwa` .
4. **Set Low:** Vai su **DVWA Security** nel menu a sinistra e imposta il livello su **Low**.

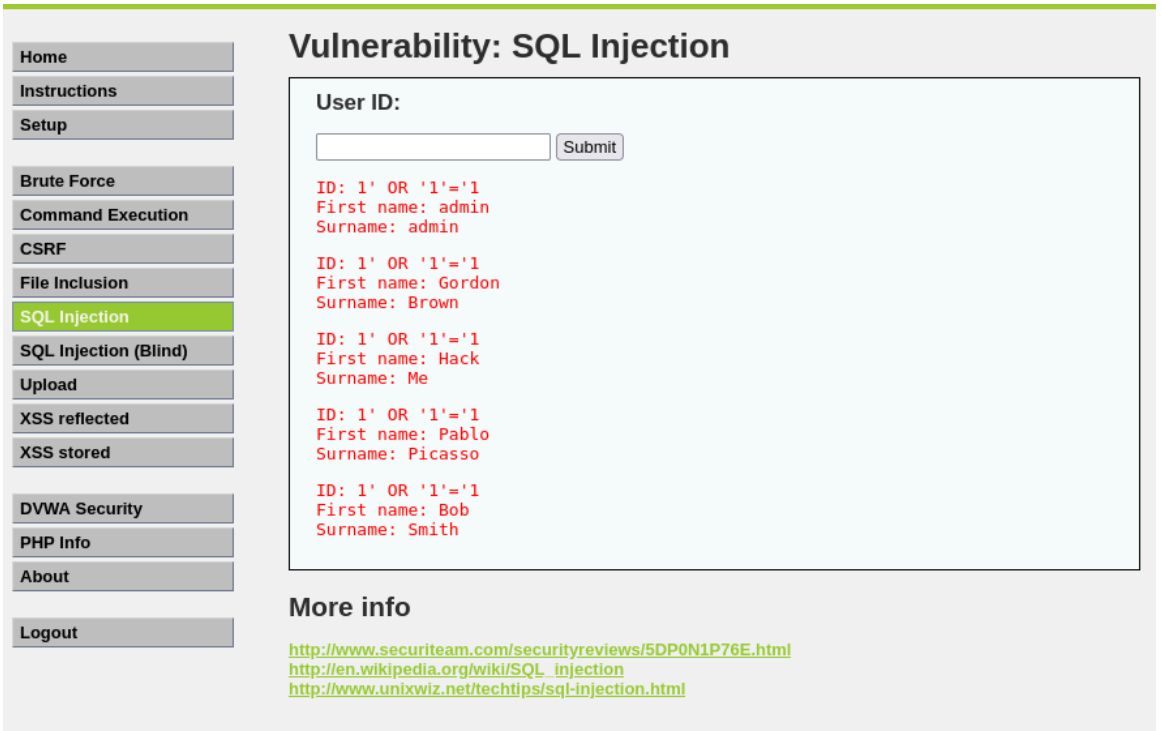
Fase 2: Eseguire lo SQL Injection

Come indicato nel PDF, l'obiettivo è **rompere la query originale** e aggiungerne una nostra.

1. Andiamo su **SQL Injection** dal menu.
2. Nel campo "User ID", inseriamo: `1' OR '1'='1`.



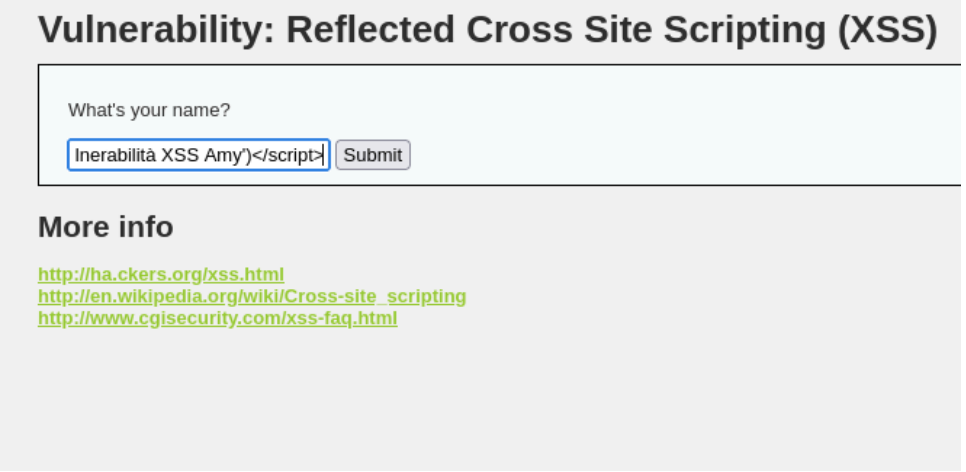
Cosa succede: Il database riceve una condizione che è sempre vera (`1=1`). Invece di mostrarti solo l'utente "1", ti mostrerà **tutti gli utenti** presenti nel database (nomi, cognomi e ID).



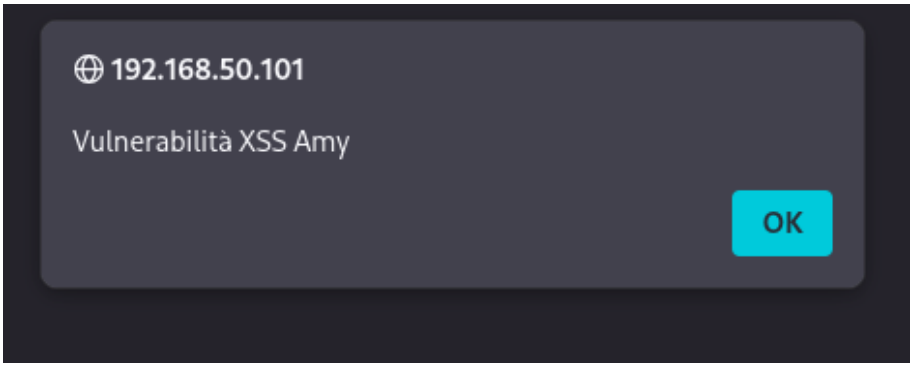
Fase 3: Eseguire l'XSS Reflected

Qui l'obiettivo è far eseguire al browser un comando che non era previsto.

- **XSS (Reflected)**.
- Nel campo "What's your name?", inseriamo:
  `<script>alert('Vulnerabilità XSS Amy')</script>`



Cosa succede: Poiché il livello è *Low*, i**l server non pulisce il testo**. Il browser legge il tag `<script>` e lo esegue, facendo apparire una finestra di avviso (pop-up).



Conclusioni

- L'**SQL Injection** serve a dimostrare che il database non filtra i caratteri speciali come l'apice `'`.
- L'**XSS** dimostra che l'applicazione accetta codice eseguibile da un utente e lo riflette sulla pagina.
- Entrambi sono possibili perché nel livello **Low** non c'è "sanitizzazione" dell'input (ovvero il server si fida ciecamente di ciò che scrive l'utente).